

# Architecture des Infrastructures Systèmes et Réseaux Sécurisées

## Support de cours — Master 2 — Bloc 2 : Concevoir et Piloter les Infrastructures Systèmes et Réseaux

**Volume horaire** : 28 heures (4 jours × 7 heures) **Niveau** : M2 **Bloc de rattachement** : Bloc 2 — Concevoir et Piloter les Infrastructures Systèmes et Réseaux

---

### Sommaire

1. Principes d'une architecture sécurisée
  2. Analyse du contexte et des exigences
  3. Segmentation, flux et contrôle des accès
  4. Choix d'hébergement, cloud et architectures hybrides
  5. Résilience, supervision et exploitabilité
  6. Mise en pratique sur cas d'architecture
  7. Références et ressources
  8. Annexes
- 

### Présentation du module

Ce module approfondit les compétences de conception d'infrastructures sécurisées déjà initiées en M1 à travers les modules Cloud Computing, Gestion des identités (IAM), Réseaux et Sécurité, DevSecOps, Renforcement Réseaux et Sécurité & Système d'exploitation, et Projet de Sécurisation d'un SI.

Il ne s'agit pas de reprendre les fondamentaux réseaux, systèmes, cloud ou IAM, mais de les **articuler dans une démarche d'architecture globale, cohérente, robuste et sécurisée**. Les étudiants apprennent à concevoir une architecture cible en tenant compte des besoins métiers, des contraintes techniques, des exigences de sécurité, des risques, de la disponibilité, de la scalabilité, de la supervision et de la maintenabilité.

Le module met l'accent sur la **posture d'architecte sécurité** : analyse du contexte, choix d'architecture, segmentation, contrôle des accès, durcissement, exposition maîtrisée, résilience, documentation et justification des arbitrages. Il prépare les étudiants à produire des livrables professionnels exploitables par une DSI, un RSSI, une équipe infrastructure ou un comité technique.

### Compétences du référentiel visées

| Code | Compétence                                                                                                                                                                                                                     |
|------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| C11  | Concevoir une infrastructure système et réseau optimisée et sécurisée en analysant les besoins métiers, en proposant des solutions conformes au schéma directeur de la DSI et en combinant des ressources locales et/ou cloud. |
| C12  | Définir, implémenter et contrôler les règles d'accès aux données et aux services en retranscrivant les règles métiers dans une solution de gestion des identités.                                                              |

| Code | Compétence                                                                                                                                                                                            |
|------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| C13  | Arbitrer la technologie d'hébergement des systèmes et applications en évaluant les ressources nécessaires, la performance, la fiabilité, la flexibilité, la scalabilité et l'optimisation des usages. |
| C14  | Concevoir une topologie réseau mono ou multisite en tenant compte des engagements de disponibilité, de capacité, de qualité de service, de résilience et de sécurité des communications.              |
| C15  | Contribuer à la mise en place, au contrôle et à l'administration de l'infrastructure en documentant la solution et en vérifiant son adéquation avec les exigences de fonctionnement.                  |
| C16  | Automatiser les processus d'intégration, de déploiement et de maintenance afin d'assurer la fiabilité, la reproductibilité et la traçabilité des mises en production.                                 |

## Objectifs d'apprentissage

À l'issue du module, l'étudiant sera capable de :

1. Analyser un besoin métier et technique afin d'en déduire les exigences d'architecture sécurisée.
2. Concevoir une architecture cible intégrant sécurité, performance, disponibilité, scalabilité et maintenabilité.
3. Définir une segmentation réseau et système adaptée au niveau de criticité des services.
4. Intégrer les règles d'accès, d'authentification, d'administration et de privilèges dans l'architecture proposée.
5. Arbitrer entre solutions on-premise, cloud, hybride, virtualisées ou conteneurisées selon les contraintes du contexte.
6. Identifier les risques liés à l'exposition, aux dépendances, aux flux, aux identités et aux composants critiques.
7. Proposer des mesures de durcissement, de supervision, de sauvegarde et de résilience adaptées.
8. Formaliser une architecture sous forme de schémas, matrices, cartographies et notes de justification.
9. Défendre des choix d'architecture auprès d'un public technique ou décisionnel.

## Organisation des 4 jours

| Jour   | Thème                                                                                            | Heures |
|--------|--------------------------------------------------------------------------------------------------|--------|
| Jour 1 | Principes d'une architecture sécurisée + Analyse du contexte et des exigences                    | 7 h    |
| Jour 2 | Segmentation, flux et contrôle des accès                                                         | 7 h    |
| Jour 3 | Choix d'hébergement, cloud et architectures hybrides + Résilience, supervision et exploitabilité | 7 h    |
| Jour 4 | Mise en pratique sur cas d'architecture + Évaluation finale                                      | 7 h    |

## 1. Principes d'une architecture sécurisée

### Jour 1 — Matinée (3,5 h)

### 1.1 Rappel des acquis M1

Les acquis du cycle M1 constituent le socle sur lequel s'appuie ce module. Avant d'aborder la posture d'architecte, il est essentiel de vérifier la maîtrise des notions suivantes :

- **Réseaux** : modèles OSI et TCP/IP, routage, commutation, VLAN, pare-feu, NAT, VPN, IDS/IPS.
- **Cloud Computing** : modèles IaaS / PaaS / SaaS, déploiements public / privé / hybride, élasticité, facturation à l'usage.

- **Gestion des identités (IAM)** : annuaires, fédération d'identité, SSO, MFA, RBAC/ABAC, principe de moindre privilège.
- **DevSecOps** : intégration de la sécurité dans les pipelines CI/CD, tests de sécurité automatisés, gestion des secrets, IaC.
- **Durcissement et sécurisation d'un SI** : baseline de configuration, désactivation des services inutiles, gestion des correctifs, journalisation.

L'objectif n'est pas de reprendre ces fondamentaux, mais de les mobiliser dans une démarche d'architecture globale.

## 1.2 Conception technique, architecture cible, architecture de sécurité et architecture d'exploitation

L'architecte sécurité doit distinguer plusieurs niveaux de conception qui s'articulent mais ne se confondent pas :

| Niveau                             | Objet                                                | Question centrale         |
|------------------------------------|------------------------------------------------------|---------------------------|
| <b>Conception technique</b>        | Choix des composants et de leur configuration        | « Comment implémenter ? » |
| <b>Architecture cible</b>          | Vision globale du SI à atteindre (schéma directeur)  | « Où allons-nous ? »      |
| <b>Architecture de sécurité</b>    | Mesures de sécurité intégrées à l'architecture cible | « Comment protéger ? »    |
| <b>Architecture d'exploitation</b> | Modes d'administration, supervision, maintenance     | « Comment faire vivre ? » |

L'erreur classique du débutant consiste à se précipiter sur la conception technique (choix d'un pare-feu, d'une solution cloud) sans avoir formalisé l'architecture cible ni l'architecture de sécurité. La posture de l'architecte consiste à **raisonner du haut vers le bas** : du besoin métier vers l'architecture cible, puis vers l'architecture de sécurité, puis vers la conception technique.

## 1.3 Principes fondamentaux de sécurité

### Défense en profondeur

La défense en profondeur consiste à superposer plusieurs couches de contrôle de sécurité indépendantes, de sorte que la défaillance ou le contournement d'une couche ne compromette pas l'ensemble du système. Inspirée du modèle militaire, cette approche a été formalisée par l'ANSSI dans ses recommandations d'hygiène informatique et reprise par le NIST.

Les couches typiques d'une défense en profondeur :

1. **Périmètre réseau** : pare-feu, filtrage, DMZ.
2. **Segmentation interne** : VLAN, micro-segmentation, ACL.
3. **Hôte / système** : durcissement, EDR, contrôle d'intégrité.
4. **Application** : validation des entrées, authentification, autorisation.
5. **Données** : chiffrement, DLP, contrôle d'accès.
6. **Identité** : MFA, PAM, moindre privilège.
7. **Supervision** : SIEM, détection, journalisation, réponse.

Un compromis sur une couche ne doit pas entraîner l'effondrement de toute la posture de sécurité.

## Principe de moindre privilège

Chaque identité (utilisateur, service, compte machine) ne doit disposer que du strict minimum de privilèges nécessaires à l'accomplissement de sa mission. Ce principe s'applique aux comptes utilisateurs comme aux comptes techniques et de service.

- Attribution de privilèges par rôle (RBAC) ou par attribut (ABAC).
- Accès à durée limitée (Just-In-Time access).
- Révocation automatique des accès temporaires.
- Séparation des tâches (Separation of Duties) pour éviter les conflits d'intérêts.

## Cloisonnement et segmentation

Le cloisonnement consiste à diviser le SI en zones isolées sur le plan logique et/ou physique, de manière à limiter la propagation d'une compromission. Il s'agit de l'application concrète du principe de défense en profondeur au niveau réseau et système.

- Réduction des mouvements latéraux en cas de compromission d'un hôte.
- Limitation de l'impact d'une fuite de données à une zone.
- Facilitation du contrôle des flux (whitelistage, inspection).

## Réduction de la surface d'attaque

La surface d'attaque désigne l'ensemble des points par lesquels un attaquant peut interagir avec le système. La réduire consiste à :

- Désactiver les services et ports non nécessaires.
- Exposer le minimum de services vers l'extérieur.
- Supprimer les comptes et privilèges inutilisés.
- Cloisonner les interfaces d'administration.
- Appliquer les correctifs de sécurité en continu.

## Résilience

La résilience est la capacité d'un système à maintenir ou rétablir un niveau de service acceptable après une perturbation. Elle se décline en :

- **Redondance** : multiplication des composants critiques.
- **Disponibilité** : architecture Haute Disponibilité (HA), clustering.
- **Reprise** : PRA (Plan de Reprise d'Activité), sauvegardes, bascule.
- **Détection** : supervision, alerting, mesures d'incident.

## 1.4 Exigences transverses

Une architecture sécurisée doit équilibrer plusieurs exigences parfois contradictoires :

| Exigence              | Définition                                             | Indicateur typique                             |
|-----------------------|--------------------------------------------------------|------------------------------------------------|
| <b>Sécurité</b>       | Confidentialité, intégrité, disponibilité, traçabilité | Conformité aux référentiels (ANSSI, ISO 27001) |
| <b>Disponibilité</b>  | Capacité à assurer le service attendu                  | SLA, MTBF, MTTR                                |
| <b>Performance</b>    | Temps de réponse, débit, latence                       | Latence p95/p99, transactions/s                |
| <b>Supervision</b>    | Visibilité sur l'état et les événements                | Couverture des métriques, alertes              |
| <b>Maintenabilité</b> | Facilité de maintenance et d'évolution                 | Temps de mise à jour, dette technique          |

| Exigence   | Définition                             | Indicateur typique         |
|------------|----------------------------------------|----------------------------|
| Conformité | Respect des obligations réglementaires | Audit, certification, RGPD |

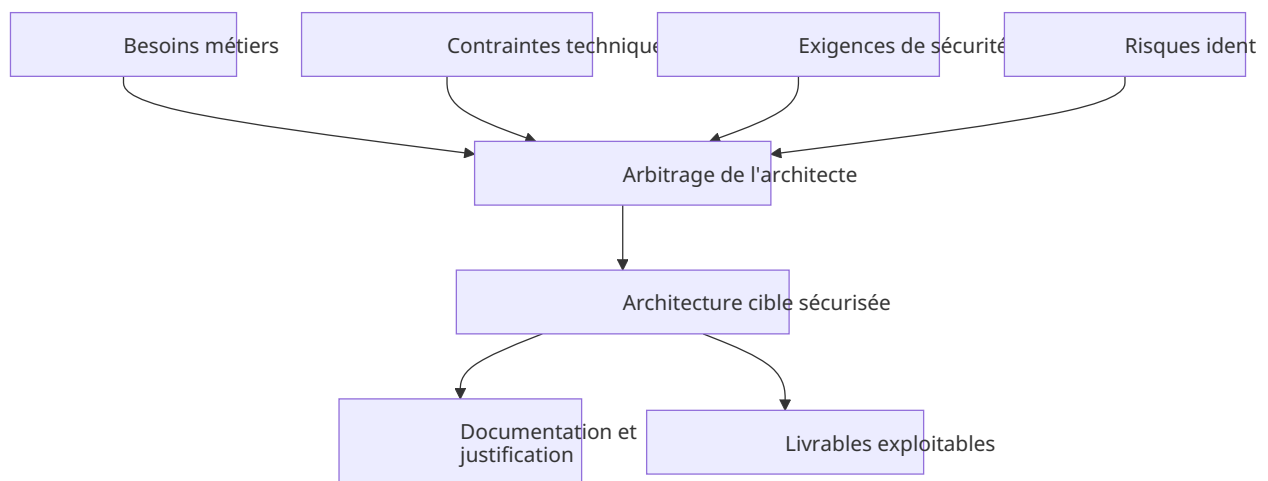
L'architecte doit arbitrer : maximiser la sécurité sans compromettre l'exploitabilité, ni l'inverse.

## 1.5 Rôle de l'architecte sécurité

L'architecte sécurité occupe une position centrale dans les arbitrages entre :

- **Besoins métiers** : ce que l'organisation veut accomplir.
- **Contraintes techniques** : ce que les technologies permettent.
- **Exigences de sécurité** : ce que la protection des actifs impose.
- **Risques** : ce qui peut compromettre les objectifs.

Sa mission ne se limite pas à « ajouter de la sécurité » : il conçoit une architecture dans laquelle la sécurité est **native et intégrée**, non ajoutée a posteriori.



### Livrables attendus de l'architecte

- Schémas d'architecture (logique, physique, flux).
- Matrices de flux (qui parle à qui, sur quel port, dans quel sens).
- Matrices d'exigences (besoins × contraintes × mesures).
- Règles d'accès et politique d'administration.
- Note de justification des arbitrages.
- Cartographie des risques résiduels.

## 2. Analyse du contexte et des exigences

Jour 1 — Après-midi (3,5 h)

## 2.1 Recueil des besoins

L'analyse du contexte est l'étape fondatrice de toute démarche d'architecture. Une architecture construite sur des besoins mal compris ou incomplets est vouée à l'échec, quelle que soit la qualité technique de sa conception.

Les besoins se recueillent selon quatre dimensions complémentaires :

### Besoins métiers

- Quelle est la finalité du système ? (service client, production, support, conformité...)
- Quels processus métier dépendent de ce système ?
- Quels sont les utilisateurs (interne, externe, partenaires) ?
- Quels sont les volumes attendus et la croissance prévisible ?
- Quelles sont les contraintes réglementaires (RGPD, NIS2, DORA, secteur spécifique) ?

### Besoins techniques

- Quelles applications et quels services doivent être hébergés ?
- Quelles sont les interdépendances entre composants ?
- Quels sont les prérequis techniques (OS, base de données, middleware) ?
- Quels sont les volumes de données et leur cycle de vie ?
- Quelles sont les contraintes de performance (latence, débit) ?

### Besoins de sécurité

- Quelle est la criticité des données traitées (confidentiel, sensible, public) ?
- Quelles sont les exigences de confidentialité, d'intégrité, de disponibilité (CIA) ?
- Quels sont les flux sensibles ou réglementés ?
- Quelles sont les obligations d'audit et de traçabilité ?
- Quelle est la tolérance au risque de l'organisation ?

### Besoins d'exploitation

- Qui administre le système (équipe interne, prestataire) ?
- Quelles sont les fenêtres de maintenance ?
- Quel niveau de disponibilité est attendu (24/7, horaires ouvrés) ?
- Quels outils de supervision sont déjà en place ?
- Quelle est la capacité de l'équipe à exploiter l'architecture proposée ?

## 2.2 Identification des actifs et des points d'exposition

L'identification des actifs critiques est alignée sur la fonction **Identify** du NIST Cybersecurity Framework 2.0, qui constitue le socle de toutes les fonctions ultérieures (Protéger, Détecter, Répondre, Rétablir).

### Actifs critiques

Un actif est critique si sa compromission (confidentialité, intégrité ou disponibilité) aurait un impact significatif sur l'organisation. Les actifs à recenser :

- **Données** : bases de données, fichiers, secrets, clés de chiffrement.
- **Services** : applications métier, API, services d'annuaire.

- **Infrastructure** : serveurs, équipements réseau, hyperviseurs.
- **Identités** : comptes administrateurs, comptes de service, comptes tiers.

### Points d'exposition

Les points d'exposition sont les interfaces par lesquelles le système est accessible depuis l'extérieur ou depuis des zones moins sûres :

- Services exposés sur Internet (web, mail, VPN).
- Interfaces d'administration (SSH, RDP, consoles web).
- Points d'intégration (API, flux partenaires).
- Postes utilisateurs (points d'entrée typiques des compromissions).
- Accès tiers et prestataires.

## 2.3 Analyse CIA et traçabilité

L'analyse des exigences de sécurité repose sur le triptyque CIA (Confidentiality, Integrity, Availability) auquel s'ajoute la traçabilité :

| Dimension              | Question                       | Mesures typiques                                  |
|------------------------|--------------------------------|---------------------------------------------------|
| <b>Confidentialité</b> | Qui peut lire ?                | Chiffrement, contrôle d'accès, cloisonnement      |
| <b>Intégrité</b>       | Qui peut modifier ?            | Signature, hash, contrôle d'accès, journalisation |
| <b>Disponibilité</b>   | Le service est-il accessible ? | Redondance, sauvegardes, anti-DDoS                |
| <b>Traçabilité</b>     | Qui a fait quoi et quand ?     | Journalisation, SIEM, immutabilité des logs       |

Pour chaque actif critique, l'architecte évalue le niveau d'exigence sur chacune de ces dimensions. Une base de données client aura une exigence de confidentialité maximale ; un site web public aura une exigence de disponibilité élevée mais une confidentialité faible.

## 2.4 Contraintes cloud, on-premise, hybrides et réglementaires

Les choix d'architecture sont contraints par :

- **Souveraineté des données** : certaines données ne peuvent pas sortir du territoire (secteur public, santé, défense). En France, le cadre SecNumCloud et les qualifications de l'ANSSI restreignent les options d'hébergement pour les données sensibles.
- **Conformité réglementaire** : RGPD (protection des données personnelles), NIS2 (entités essentielles et importantes), DORA (secteur financier), HDS (santé).
- **Contraintes organisationnelles** : budget, compétences disponibles, maturité de l'organisation, schéma directeur existant.
- **Contraintes techniques** : latence, dépendances, compatibilité, legacy.

## 2.5 Formalisation d'une matrice d'exigences et d'hypothèses

La matrice d'exigences synthétise l'ensemble des besoins recueillis et sert de référence pour les arbitrages d'architecture.

**Exemple de matrice d'exigences :**

| ID  | Catégorie | Exigence                                       | Priorité | Source           |
|-----|-----------|------------------------------------------------|----------|------------------|
| E01 | Métier    | Disponibilité 24/7 pour le service client      | Critique | Direction métier |
| E02 | Sécurité  | Chiffrement des données au repos et en transit | Élevée   | RSSI             |

| ID  | Catégorie    | Exigence                                | Priorité | Source           |
|-----|--------------|-----------------------------------------|----------|------------------|
| E03 | Conformité   | Hébergement souverain (SecNumCloud)     | Critique | DPO              |
| E04 | Performance  | Latence < 100 ms pour l'API             | Élevée   | Équipe produit   |
| E05 | Exploitation | Supervision centralisée (SIEM existant) | Moyenne  | Équipe infra     |
| E06 | Scalabilité  | Capacité à absorber x3 charge nominale  | Moyenne  | Direction métier |

Les **hypothèses d'architecture** sont les postulats posés faute d'information complète. Elles doivent être explicitement documentées pour validation :

- « H1 : Les utilisateurs externes accèdent via un portail web unique. »
- « H2 : Les sauvegardes sont stockées dans une zone géographique distincte. »
- « H3 : L'équipe d'exploitation maîtrise les technologies retenues. »

Une hypothèse non documentée est un risque non maîtrisé.

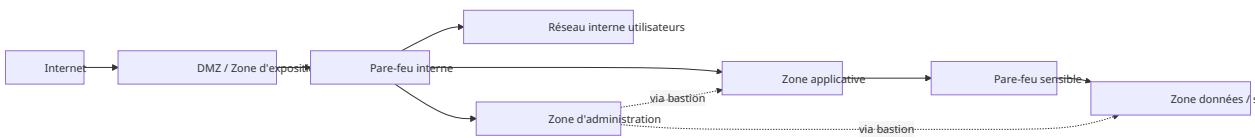
### 3. Segmentation, flux et contrôle des accès

Jour 2 — Journée complète (7 h)

#### 3.1 Conception de zones de sécurité

La segmentation est l'application concrète du principe de défense en profondeur au niveau réseau. Elle consiste à diviser le SI en zones de sécurité de criticité croissante, séparées par des dispositifs de filtrage.

##### Zones typiques



| Zone                  | Rôle                                | Niveau de confiance | Exposition           |
|-----------------------|-------------------------------------|---------------------|----------------------|
| Internet              | Extérieur non contrôlé              | Aucun               | —                    |
| DMZ                   | Services exposés (web, mail, VPN)   | Faible              | Publique filtrée     |
| Réseau interne        | Postes utilisateurs                 | Moyen               | Interne              |
| Zone applicative      | Serveurs applicatifs                | Moyen-élevé         | Interne filtrée      |
| Zone données          | Bases de données, stockage sensible | Élevé               | Interne très filtrée |
| Zone d'administration | Outils d'admin, bastion, PAM        | Élevé               | Interne très filtrée |
| Zone isolée           | Environnements sensibles (OT, PKI)  | Maximum             | Isolée               |

##### Principes de conception des zones

1. **Cloisonnement strict** : chaque zone est séparée des autres par un dispositif de filtrage (pare-feu, ACL, micro-segmentation).

2. **Filtrage par liste blanche** : seuls les flux explicitement autorisés sont permis ; tout le reste est interdit (deny by default).
3. **Séparation administration / production** : l'administration ne se fait jamais depuis le réseau utilisateur.
4. **Découpage par criticité** : les composants de même niveau de criticité sont regroupés ; les composants de criticité différente sont séparés.
5. **DMZ dédiée** : les services exposés à Internet sont isolés dans une DMZ distincte du réseau interne.

## 3.2 Cartographie des flux

La cartographie des flux est un livrable central de l'architecte. Elle répond à la question : « Qui peut communiquer avec qui, sur quel port, dans quel sens, avec quelle justification ? »

### Matrice de flux

Une matrice de flux est un tableau croisé qui répertorie l'ensemble des communications autorisées entre zones :

| Source ↓ / Destination → | Internet         | DMZ           | Internauts | Applicative              | Données       | Admin |
|--------------------------|------------------|---------------|------------|--------------------------|---------------|-------|
| Internet                 | —                | 443/tcp (WAF) | x          | x                        | x             | x     |
| DMZ                      | Réponses         | —             | x          | 8080/tcp (reverse-proxy) | x             | x     |
| Internauts               | 443/tcp (sortie) | x             | —          | x                        | x             | x     |
| Applicative              | x                | x             | x          | —                        | 5432/tcp (PG) | x     |
| Données                  | x                | x             | x          | Réponses                 | —             | x     |
| Admin                    | x                | Bastion       | Bastion    | Bastion                  | Bastion       | —     |

### Règles de cartographie

- Chaque flux doit être **justifié** par un besoin métier ou technique.
- Le sens du flux est précisé (initiateur → récepteur).
- Les protocoles et ports sont explicites.
- Les flux interdits sont marqués explicitement (x), pas seulement absents.
- Les flux surveillés (IDS/IPS) sont identifiés.
- Les flux soumis à inspection (proxy, WAF) sont annotés.

L'absence de matrice de flux est l'une des lacunes les plus fréquentes dans les architectures réelles. Sans elle, il est impossible d'auditer ou de durcir la segmentation.

## 3.3 Intégration des règles IAM, MFA, bastion et PAM

La segmentation réseau ne suffit pas : elle doit être complétée par un contrôle strict des identités et des accès.

## Authentification et MFA

- **MFA (Multi-Factor Authentication)** obligatoire pour :
  - Tout accès administrateur.
  - Tout accès distant (VPN, portail).
  - Tout accès à des données sensibles.
- Le second facteur doit être résistant au phishing (FIDO2/WebAuthn préférable au SMS).

## Bastion (jump host)

Le bastion est un hôte intermédiaire durci qui sert de point de passage unique pour l'administration des serveurs. L'ANSSI recommande l'usage de bastions dans son guide « Recommandations relatives à l'administration sécurisée des systèmes d'information » (ANSSI-PA-022, v3.0, mai 2021).

Principes :

- Les administrateurs ne se connectent jamais directement aux serveurs cibles.
- Le bastion centralise l'authentification, l'autorisation et la journalisation des sessions.
- Les sessions administrateur sont enregistrées (session recording).
- Le bastion est lui-même durci et placé dans une zone dédiée.

## PAM (Privileged Access Management)

Le PAM va au-delà du bastion en gérant le cycle de vie des accès privilégiés :

- **Coffre-fort de credentials** : les mots de passe administrateurs ne sont jamais connus des administrateurs ; ils sont injectés à la volée et rotés après usage.
- **Accès Just-In-Time (JIT)** : les privilèges élevés sont accordés pour une durée limitée et automatiquement révoqués.
- **Approvisionnement et déprovisionnement** : gestion du cycle de vie des comptes à privilèges.
- **Audit et session recording** : traçabilité complète des actions à privilèges.

## Accès administrateurs et accès tiers

- Séparation stricte des comptes d'administration et des comptes nominatifs.
- Comptes dédiés pour les prestataires (jamais de compte partagé).
- Accès tiers via un environnement dédié (enclave) avec credentials à expiration.
- Supervision renforcée des accès tiers (alerting sur comportement anormal).

## 3.4 Sécurisation des communications

| Type de communication    | Risques                               | Mesures                                             |
|--------------------------|---------------------------------------|-----------------------------------------------------|
| Internes                 | Écoute, usurpation, mouvement latéral | Segmentation, 802.1X, chiffrement sensible          |
| Externes (vers Internet) | Écoute, interception, spoofing        | TLS mutuel, VPN, WAF                                |
| Inter-sites              | Écoute sur WAN, compromission liaison | VPN site-à-site, chiffrement, redondance            |
| Cloud / on-premise       | Exposition, mauvaise config           | Private link, ExpressRoute, VPN, segmentation cloud |
| Administration           | Vol de credentials, hijacking         | Bastion, PAM, MFA, canal dédié                      |

### 3.5 Réduction des mouvements latéraux

Les mouvements latéraux désignent la capacité d'un attaquant, après compromission d'un point initial, à se déplacer latéralement vers d'autres systèmes pour atteindre ses objectifs. Les mesures de réduction :

- **Micro-segmentation** : cloisonnement au niveau de l'hôte ou du workload, pas seulement au niveau du VLAN.
- **Filtrage est-ouest** : pare-feu interne, ACL, service mesh.
- **Restriction des protocoles d'administration** : interdiction de RDP/SSH direct ; passage par bastion uniquement.
- **Limitation des privilèges** : moindre privilège, JIT, PAM.
- **Détection** : EDR, détection de comportement anormal, UEBA.

## 4. Choix d'hébergement, cloud et architectures hybrides

Jour 3 — Matinée (3,5 h)

### 4.1 Arbitrage entre modes d'hébergement

Le choix d'hébergement est un arbitrage majeur de l'architecte. Il n'existe pas de « bonne réponse » universelle : le choix dépend du contexte, des contraintes et des objectifs.

| Mode                    | Avantages                                             | Inconvénients                                   | Cas d'usage                               |
|-------------------------|-------------------------------------------------------|-------------------------------------------------|-------------------------------------------|
| <b>Serveur dédié</b>    | Maîtrise totale, performance, isolation physique      | Coût, maintenance, scalabilité limitée          | Charges sensibles, souveraineté, legacy   |
| <b>Virtualisation</b>   | Consolidation, souplesse, snapshots                   | Surcoût hyperviseur, dépendance                 | Charges variées, environnements multiples |
| <b>Conteneurisation</b> | Légèreté, portabilité, densité, CI/CD                 | Sécurité partagée, orchestration complexe       | Microservices, cloud-native, DevSecOps    |
| <b>Cloud public</b>     | Élasticité, rapidité, services managés, coût variable | Dépendance, souveraineté, shared responsibility | Charges variables, innovation, POC        |
| <b>Cloud privé</b>      | Maîtrise, conformité, isolation                       | Coût d'investissement, complexité               | Données sensibles, réglementé             |
| <b>Hybride</b>          | Flexibilité, optimisation, continuité                 | Complexité d'intégration, sécurité inter-zones  | Migration progressive, charges mixtes     |

### 4.2 Critères de choix

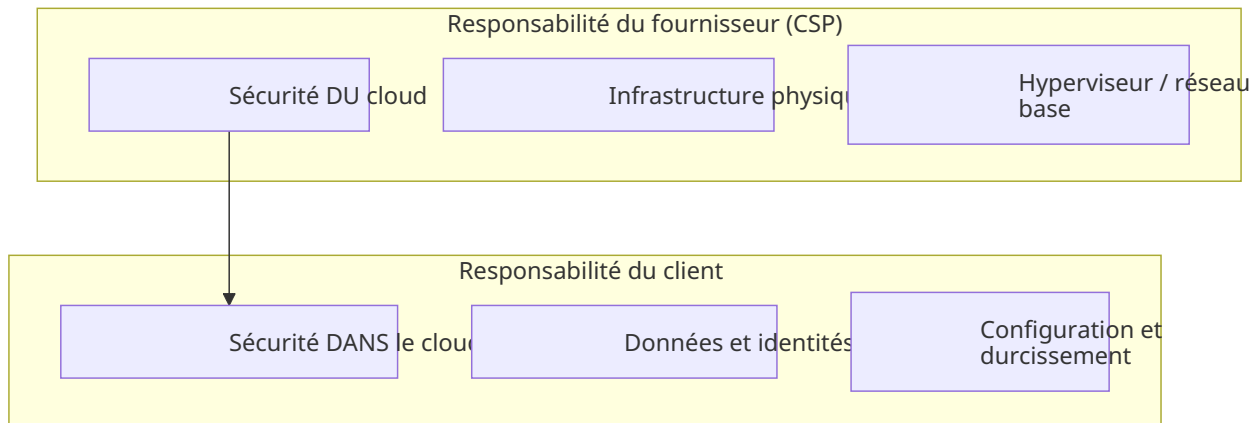
L'arbitrage se structure autour de critères explicites :

1. **Performance** : latence, débit, I/O, besoins spécifiques (GPU, mémoire).
2. **Disponibilité** : SLA requis, tolérance aux pannes, PRA.
3. **Coût** : TCO (Total Cost of Ownership), CapEx vs OpEx, modèle de facturation.
4. **Sécurité** : souveraineté, conformité, responsabilité partagée, exposition.
5. **Scalabilité** : capacité à absorber la croissance, élasticité.
6. **Souveraineté** : localisation des données, qualification (SecNumCloud).
7. **Exploitation** : compétences disponibles, outillage, automatisation.

L'architecte doit pondérer ces critères selon le contexte. Pour un service bancaire, la sécurité et la conformité priment ; pour une startup, le coût et la scalabilité.

### 4.3 Modèle de responsabilité partagée

Le modèle de responsabilité partagée est fondamental en cloud. La responsabilité de la sécurité est répartie entre le fournisseur de cloud (CSP) et le client, et cette répartition varie selon le mode de service :



| Modèle | Fournisseur gère                                | Client gère                                          |
|--------|-------------------------------------------------|------------------------------------------------------|
| IaaS   | Infrastructure, virtualisation, réseau physique | OS, middleware, applications, données, identités     |
| PaaS   | + OS, runtime, middleware                       | Applications, données, identités, configuration      |
| SaaS   | + Applications                                  | Données, identités, accès, configuration applicative |

L'erreur la plus fréquente en cloud est de croire que le fournisseur gère tout. En IaaS, le client reste responsable de l'OS, du durcissement, des correctifs et de la configuration.

### 4.4 Sécurisation des accès et configurations cloud

#### Accès

- **IAM cloud natif** : politiques de moindre privilège, rôles et comptes, conditions d'accès (IP, MFA, tag).
- **Rotation des clés d'API** : cycle de vie automatique, révocation.
- **Fédération d'identité** : SSO depuis l'annuaire d'entreprise, pas de comptes locaux.
- **Accès console** : MFA obligatoire, conditional access, session monitoring.

#### Secrets

- Utilisation d'un service de gestion de secrets (AWS Secrets Manager, Azure Key Vault, HashiCorp Vault).
- Pas de secrets en clair dans le code, les images, ou les variables d'environnement non chiffrées.
- Rotation automatique des secrets.
- Audit des accès aux secrets.

#### Configuration

- **Infrastructure as Code (IaC)** : Terraform, Bicep, CloudFormation pour des configurations reproductibles et auditées.

- **Durcissement des images** : golden images, CIS Benchmarks appliqués, scan de vulnérabilités.
- **Configuration drift** : détection des écarts entre l'état désiré et l'état réel.
- **Policy as Code** : OPA, Azure Policy, AWS Config Rules pour appliquer automatiquement les règles de sécurité.

## 4.5 Risques spécifiques au cloud

| Risque                        | Description                               | Mesure                                        |
|-------------------------------|-------------------------------------------|-----------------------------------------------|
| <b>Mauvaise configuration</b> | Bucket public, SG ouvert, secrets exposés | Policy as Code, CSPM, audit continu           |
| <b>Dépendance fournisseur</b> | Vendor lock-in, coût de sortie            | Architecture portable, abstraction, IaC       |
| <b>Exposition publique</b>    | Services exposés par erreur               | Inventaire des expositions, WAF, segmentation |
| <b>Shadow IT</b>              | Ressources créées hors contrôle           | Guardrails, landing zones, TAG obligatoire    |
| <b>Fuite de données</b>       | Exfiltration, mauvais partage             | DLP, chiffrement, contrôle des comptes        |
| <b>Coût incontrôlé</b>        | Consommation non maîtrisée                | Budgets, alertes, FinOps                      |

## 4.6 Frameworks d'architecture cloud

### AWS Well-Architected Framework

Le framework AWS Well-Architected est structuré autour de **6 piliers** :

1. **Operational Excellence** : exécution et suivi des workloads.
2. **Security** : protection des données, des systèmes et des actifs.
3. **Reliability** : capacité à fonctionner et se rétablir après défaillance.
4. **Performance Efficiency** : utilisation efficace des ressources.
5. **Cost Optimization** : optimisation du coût.
6. **Sustainability** : impact environnemental.

### Microsoft Cloud Adoption Framework et Azure Well-Architected Framework

Le Cloud Adoption Framework (CAF) de Microsoft fournit une méthodologie structurée pour l'adoption du cloud Azure, couvrant la stratégie, le plan, la préparation, la migration et la gouvernance. Le Azure Well-Architected Framework évalue les workloads selon 5 piliers : fiabilité, sécurité, optimisation des coûts, excellence opérationnelle, efficacité de performance.

Ces frameworks sont utiles même hors de leur écosystème : ils structurent la réflexion de l'architecte sur les compromis à arbitrer.

## 5. Résilience, supervision et exploitabilité

Jour 3 — Après-midi (3,5 h)

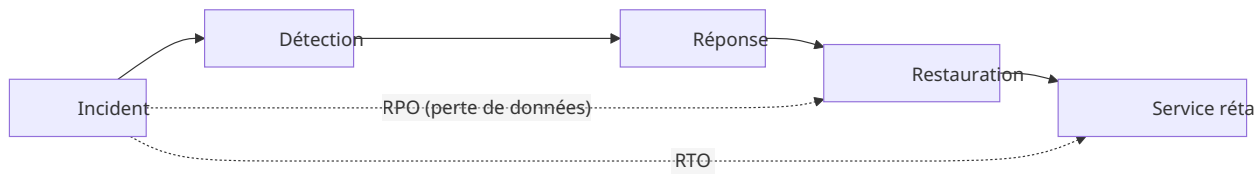
### 5.1 Continuité et reprise d'activité

L'architecture doit être conçue pour absorber les défaillances et rétablir le service. Deux plans structurent cette dimension :

| Plan                                | Objet                               | Horizon                |
|-------------------------------------|-------------------------------------|------------------------|
| PCA (Plan de Continuité d'Activité) | Maintien du service en mode dégradé | Immédiat — court terme |
| PRA (Plan de Reprise d'Activité)    | Rétablissement complet du service   | Court — moyen terme    |

Métriques clés

- **RTO (Recovery Time Objective)** : durée maximale acceptable pour rétablir le service.
- **RPO (Recovery Point Objective)** : perte de données maximale acceptable (exprimée en temps).
- **MTBF (Mean Time Between Failures)** : temps moyen entre deux pannes.
- **MTTR (Mean Time To Recovery)** : temps moyen de rétablissement.



5.2 Sauvegardes et redondance

Sauvegardes

La stratégie de sauvegarde suit la règle **3-2-1** :

- **3** copies des données.
- **2** supports différents (disque + bande, on-premise + cloud).
- **1** copie hors site (et idéalement hors ligne — air gap).

Principes :

- Sauvegardes **testées** régulièrement (une sauvegarde non testée est une sauvegarde inconnue).
- Sauvegardes **chiffrées**.
- **Immuables** si possible (protection contre les ransomwares).
- **Documentées** : procédure de restauration, temps de restauration estimé.

Redondance

- **Active/active** : les deux systèmes fonctionnent en parallèle et partagent la charge.
- **Active/passive** : un système est en attente et bascule en cas de défaillance.
- **Multi-AZ / multi-région** : répartition géographique pour tolérer une panne régionale.
- **Load balancing** : répartition de charge avec health checks.

5.3 Supervision et journalisation

La supervision est alignée sur les fonctions **Detect** et **Respond** du NIST CSF 2.0. Elle doit être conçue dès l'architecture, pas ajoutée après.

Couches de supervision

| Couche         | Indicateurs                        | Outils typiques             |
|----------------|------------------------------------|-----------------------------|
| Infrastructure | CPU, RAM, disque, réseau           | Prometheus, Zabbix, Datadog |
| Application    | Latence, taux d'erreur, throughput | APM, OpenTelemetry          |

| Couche   | Indicateurs                            | Outils typiques    |
|----------|----------------------------------------|--------------------|
| Sécurité | Événements de sécurité, anomalies      | SIEM, EDR, IDS/IPS |
| Logs     | Journaux d'audit, d'accès, applicatifs | ELK, Loki, SIEM    |
| Métier   | KPI métier, disponibilité service      | Dashboards métier  |

### Journalisation

- **Centralisation** : tous les logs sont envoyés vers une plateforme centralisée (SIEM).
- **Immuabilité** : les logs de sécurité ne doivent pas être modifiables par le système surveillé.
- **Corrélation** : les événements sont corrélés pour détecter les attaques multi-étapes.
- **Rétention** : durée de conservation conforme aux exigences réglementaires et d'audit.

Les journaux sont la mémoire du système. Sans journalisation, pas de détection, pas d'investigation, pas de preuve.

## 5.4 Exploitabilité et automatisation

Une architecture inexploitable est une architecture défaillante. L'architecte doit anticiper l'exploitation dès la conception :

### Administration

- Procédures documentées (runbooks).
- Accès via bastion/PAM uniquement.
- Séparation des environnements (dev / test / prod).
- Pas de modification manuelle en production.

### Mises à jour

- Stratégie de patch management (fréquence, urgence, rollback).
- Fenêtres de maintenance définies.
- Tests de mise à jour en environnement de pré-prod.
- Automatisation du déploiement des correctifs.

### Automatisation (C16)

- **Infrastructure as Code** : Terraform, Pulumi, Bicep — la infrastructure est décrite en code, versionnée, testée.
- **CI/CD** : pipelines de déploiement automatisés avec étapes de sécurité (SAST, DAST, scan d'images, policy checks).
- **Configuration Management** : Ansible, Chef, Puppet pour la configuration des serveurs.
- **GitOps** : l'état désiré est stocké dans Git, les outils convergent vers cet état.

Bénéfices de l'automatisation :

- **Reproductibilité** : un déploiement identique à chaque fois.
- **Traçabilité** : chaque changement est versionné et auditable.
- **Fiabilité** : élimination des erreurs manuelles.
- **Rapidité** : déploiements fréquents et sûrs.

## 5.5 Documentation

La documentation est un livrable central de l'architecte. Le guide ANSSI sur l'administration sécurisée insiste sur l'importance de maintenir à jour la documentation du SI : schémas d'architecture, plans d'adressage IP, matrices de flux, inventaire des comptes.

Livrables documentaires attendus :

| Document                 | Objet                                 | Audience              |
|--------------------------|---------------------------------------|-----------------------|
| Schéma d'architecture    | Vue d'ensemble                        | DSI, comité technique |
| Matrice de flux          | Cartographie des communications       | Équipe infra, audit   |
| Matrice d'exigences      | Synthèse des besoins                  | Sponsor, DSI          |
| Règles d'accès           | Politique d'accès et d'administration | RSSI, équipe infra    |
| Note de justification    | Arbitrages et choix                   | DSI, RSSI, comité     |
| Cartographie des risques | Risques résiduels et mesures          | RSSI, direction       |
| Runbooks                 | Procédures d'exploitation             | Équipe exploitation   |

## 5.6 Cohérence architecture / sécurité / exploitation

L'architecte vérifie la cohérence globale de la solution :

- L'architecture permet-elle l'exploitation prévue (maintenance, supervision, PRA) ?
- Les mesures de sécurité entravent-elles l'exploitation de manière irréaliste ?
- Les procédures d'incident sont-elles compatibles avec l'architecture ?
- Les outils de supervision couvrent-ils tous les composants critiques ?
- Les sauvegardes sont-elles restaurables dans les délais RTO ?

Une architecture qui ignore l'exploitation sera contournée par les équipes, ce qui crée des risques de sécurité.

## 6. Mise en pratique sur cas d'architecture

Jour 4 — Matinée et évaluation (7 h)

### 6.1 Démarche de mise en pratique

Le jour 4 est consacré à la mise en application des concepts sur un cas d'architecture concret. Les étudiants travaillent en binôme et suivent la démarche complète de l'architecte :

1. **Analyse du contexte** : lecture du scénario, identification des besoins.
2. **Formalisation des exigences** : matrice d'exigences et hypothèses.
3. **Conception de l'architecture cible** : schéma, zones, flux.
4. **Définition des règles d'accès** : segmentation, IAM, bastion, PAM.
5. **Choix d'hébergement** : justification des arbitrages.
6. **Mesures de résilience** : sauvegardes, supervision, PRA.
7. **Identification des risques résiduels** : cartographie et mesures complémentaires.

8. **Rédaction de la note de justification** : argumentation des arbitrages.

9. **Restitution orale** : présentation synthétique.

## 6.2 Scénario d'évaluation (voir livrable Évaluation)

Le scénario détaillé de mise en situation est fourni dans le livrable « Évaluation finale » (canvas séparé). Il s'agit d'une entreprise fictive avec des besoins métiers, des contraintes techniques et des exigences de sécurité que les étudiants doivent analyser et auxquels ils doivent répondre par une architecture cible sécurisée.

## 6.3 Grille de qualité d'un dossier d'architecture

Un dossier d'architecture de qualité doit répondre aux critères suivants :

| Critère                              | Indicateur de qualité                                        |
|--------------------------------------|--------------------------------------------------------------|
| <b>Pertinence de l'analyse</b>       | Tous les besoins du scénario sont identifiés et hiérarchisés |
| <b>Cohérence de l'architecture</b>   | Les choix répondent aux exigences ; pas de contradiction     |
| <b>Exhaustivité de la sécurité</b>   | CIA, segmentation, accès, durcissement, supervision couverts |
| <b>Réalisme des choix techniques</b> | Choix justifiés et adaptés au contexte et au budget          |
| <b>Qualité de la segmentation</b>    | Zones définies, matrice de flux complète et justifiée        |
| <b>Adéquation des règles d'accès</b> | Moindre privilège, MFA, bastion, PAM intégrés                |
| <b>Résilience</b>                    | RTO/RPO, sauvegardes, redondance, PRA documentés             |
| <b>Clarté de la documentation</b>    | Schémas lisibles, matrices exploitables, note argumentée     |

# 7. Références et ressources

## 7.1 Référentiels de sécurité

| Référentiel                                                                   | Éditeur | Description                                                                                            |
|-------------------------------------------------------------------------------|---------|--------------------------------------------------------------------------------------------------------|
| <a href="#">Guide d'hygiène informatique</a>                                  | ANSSI   | 42 recommandations fondamentales applicables par toute organisation                                    |
| <a href="#">Recommandations relatives à l'administration sécurisée des SI</a> | ANSSI   | Guide ANSSI-PA-022, v3.0 (mai 2021) sur l'architecture d'administration sécurisée                      |
| <a href="#">NIST Cybersecurity Framework 2.0</a>                              | NIST    | Cadre structuré autour de 6 fonctions : Govern, Identify, Protect, Detect, Respond, Recover            |
| <a href="#">NIST SP 800-207 — Zero Trust Architecture</a>                     | NIST    | Publication de référence sur l'architecture Zero Trust (août 2020)                                     |
| <a href="#">CIS Critical Security Controls v8</a>                             | CIS     | 18 contrôles de sécurité prioritaires pour renforcer la posture                                        |
| <a href="#">CIS Benchmarks</a>                                                | CIS     | Recommandations de configuration sécurisée par système/service/cloud                                   |
| <a href="#">ISO/IEC 27001:2022</a>                                            | ISO     | Exigences pour le SMSI (système de management de la sécurité de l'information)                         |
| <a href="#">ISO/IEC 27002:2022</a>                                            | ISO     | Mesures de sécurité — 93 contrôles restructurés en 4 thèmes (remplace la version 2013 à 114 contrôles) |
| <a href="#">MITRE ATT&amp;CK Enterprise Matrix</a>                            | MITRE   | Catalogue des tactiques et techniques d'attaque pour anticiper les menaces                             |
| <a href="#">OWASP Top 10:2021</a>                                             | OWASP   | Top 10 des risques applicatifs web                                                                     |

| Référentiel                          | Éditeur | Description                                                      |
|--------------------------------------|---------|------------------------------------------------------------------|
| <a href="#">OWASP Cloud Security</a> | OWASP   | Ressources sur la sécurité cloud et les mauvaises configurations |

## 7.2 Frameworks d'architecture cloud

| Framework                                          | Éditeur   | Description                                                                                  |
|----------------------------------------------------|-----------|----------------------------------------------------------------------------------------------|
| <a href="#">AWS Well-Architected Framework</a>     | AWS       | 6 piliers : Operational Excellence, Security, Reliability, Performance, Cost, Sustainability |
| <a href="#">Microsoft Cloud Adoption Framework</a> | Microsoft | Méthodologie d'adoption cloud Azure : stratégie, plan, préparation, migration, gouvernance   |
| <a href="#">Azure Well-Architected Framework</a>   | Microsoft | Évaluation des workloads selon 5 piliers : fiabilité, sécurité, coûts, ops, performance      |

## 7.3 Ressources complémentaires

- **SecNumCloud** : référentiel de qualification de l'ANSSI pour les prestataires de services cloud sécurisés.
- **ENISA** : agence européenne de cybersécurité — guides sur la sécurité cloud et l'architecture.
- **Cloud Security Alliance (CSA)** : guides et matrice de contrôles (CCM) pour la sécurité cloud.
- **SANS Institute** : références et bonnes pratiques en sécurité système et réseau.

# 8. Annexes

## Annexe A — Glossaire

| Terme              | Définition                                                                           |
|--------------------|--------------------------------------------------------------------------------------|
| <b>CIA</b>         | Confidentiality, Integrity, Availability — triptyque fondamental de la sécurité      |
| <b>DMZ</b>         | Demilitarized Zone — zone tampon entre Internet et le réseau interne                 |
| <b>PAM</b>         | Privileged Access Management — gestion des accès à privilèges                        |
| <b>EDR</b>         | Endpoint Detection and Response — détection et réponse sur les postes                |
| <b>SIEM</b>        | Security Information and Event Management — centralisation et corrélation des logs   |
| <b>RTO / RPO</b>   | Recovery Time / Point Objective — objectifs de rétablissement et de perte de données |
| <b>PCA / PRA</b>   | Plan de Continuité / Reprise d'Activité                                              |
| <b>IaC</b>         | Infrastructure as Code — infrastructure décrite en code versionné                    |
| <b>CSPM</b>        | Cloud Security Posture Management — gestion de la posture de sécurité cloud          |
| <b>JIT</b>         | Just-In-Time — accès temporaire à privilèges                                         |
| <b>ZTA</b>         | Zero Trust Architecture — modèle de confiance zéro                                   |
| <b>SecNumCloud</b> | Qualification ANSSI pour les services cloud sécurisés                                |

## Annexe B — Checklist d'architecture sécurisée

### Analyse

- ☐ Besoins métiers recueillis et documentés
- ☐ Besoins techniques recueillis
- ☐ Besoins de sécurité (CIA) définis par actif
- ☐ Besoins d'exploitation identifiés

- ☐ Matrice d'exigences formalisée
- ☐ Hypothèses documentées et validées
- ☐ Actifs critiques identifiés
- ☐ Points d'exposition cartographiés

### Conception

- ☐ Zones de sécurité définies
- ☐ Matrice de flux complète et justifiée
- ☐ Règles d'accès (deny by default)
- ☐ MFA généralisée pour les accès sensibles
- ☐ Bastion / PAM intégrés
- ☐ Choix d'hébergement justifié
- ☐ Modèle de responsabilité partagée documenté
- ☐ Durcissement prévu (CIS Benchmarks)
- ☐ Chiffrement au repos et en transit
- ☐ Gestion des secrets prévue

### Résilience

- ☐ RTO / RPO définis par service
- ☐ Stratégie de sauvegarde 3-2-1
- ☐ Redondance des composants critiques
- ☐ PRA documenté
- ☐ Tests de restauration planifiés

### Exploitation

- ☐ Supervision couvre tous les composants
- ☐ Journalisation centralisée (SIEM)
- ☐ Procédures d'administration documentées
- ☐ Automatisation (IaC, CI/CD) prévue
- ☐ Runbooks disponibles

### Documentation

- ☐ Schéma d'architecture
- ☐ Matrice de flux
- ☐ Règles d'accès
- ☐ Note de justification
- ☐ Cartographie des risques résiduels
- ☐ Inventaire des composants

## Annexe C — Correspondance avec le NIST CSF 2.0

| Fonction NIST CSF 2.0 | Articulation dans le cours                                                |
|-----------------------|---------------------------------------------------------------------------|
| <b>Govern</b>         | Arbitrages, documentation, gouvernance de l'architecture (Jour 1 et 4)    |
| <b>Identify</b>       | Analyse du contexte, identification des actifs, exigences (Jour 1)        |
| <b>Protect</b>        | Segmentation, accès, durcissement, chiffrement, hébergement (Jour 2 et 3) |
| <b>Detect</b>         | Supervision, journalisation, SIEM (Jour 3)                                |
| <b>Respond</b>        | Procédures d'incident, alerting (Jour 3)                                  |

| Fonction NIST CSF 2.0 | Articulation dans le cours            |
|-----------------------|---------------------------------------|
| Recover               | Sauvegardes, PRA, redondance (Jour 3) |

---

*Document de support de cours — Architecture des Infrastructures Systèmes et Réseaux Sécurisées — M2 — 28 heures*